



Akrites: Building the Open-Source Defense Layer for the AI Vulnerability Era

Coordinated, confidential vulnerability remediation for the open source software critical infrastructure depends on

Weathering the Storm: Cybersecurity in the AI Era
August 4, 2027

Agenda

Who?

What?

Why?

How?

What's Next?



Who is this guy?

CRob, n, adj, and v

Pronunciation: U.S. (K-rowb)

`chmod 666 crob.md`

Security Lorax

44th level Dungeon Master

27th level Securityologist

Pirate-enthusiast & hat-owner

Chief Technology Officer & Chief Security Architect,
Akrites + OpenSSF - Linux Foundation

Involved in upstream OSS CVD for ~15 years



What?



AI-Powered Threat Backlog

Widespread access to automated AI tools has enabled rapid codebase scanning, generating a massive backlog of potential vulnerability reports.

The Coordination Gap

No neutral, centralized entity exists to efficiently coordinate, validate, and route these complex reports to upstream maintainers.

Akrites: The Neutral Broker

Akrites acts as a trusted intermediary with our SIRT partners and Finders using advanced tools to safely land and responsibly disclose verified vulnerabilities.

Why "Akrites"?

The name comes from the *Akritai*, the Byzantine Empire's frontier guardians, who stood watch where threats arrived first and defenses were thinnest. In modern software, that frontier is upstream: the open source projects everything depends on. Akrites is the industry standing that watch together, alongside the maintainers who have held it alone for too long. Fittingly, the root of the name is the same word that gives us *critical*, which is exactly the software this effort exists to defend.



Why is an OSS SIRT needed?

Some OSS CVE “Fun Facts”

As of July 24, 2026, there were **530** entities listed as CVE Numbering Authorities (CNAs) in the [CVE program](#)

Of those, **142** mention “open source” in their profile

Of those, **56** *generously* could be considered very OSS-adjacent/involved

Broadly, with a few exceptions, those entities state something like this about their scope:

“<vendor> products and vulnerabilities in third-party software discovered by <vendor> that are not in another CNA’s scope .”

Github (which roughly houses 80% of all publicly available OSS projects) in their [2025 State of the Octoverse](#) report tells us there are over **630mil** projects homed there.

~60 CNAs < 630mil+ projects

Circles of Trust

Complex Stakeholder Landscape

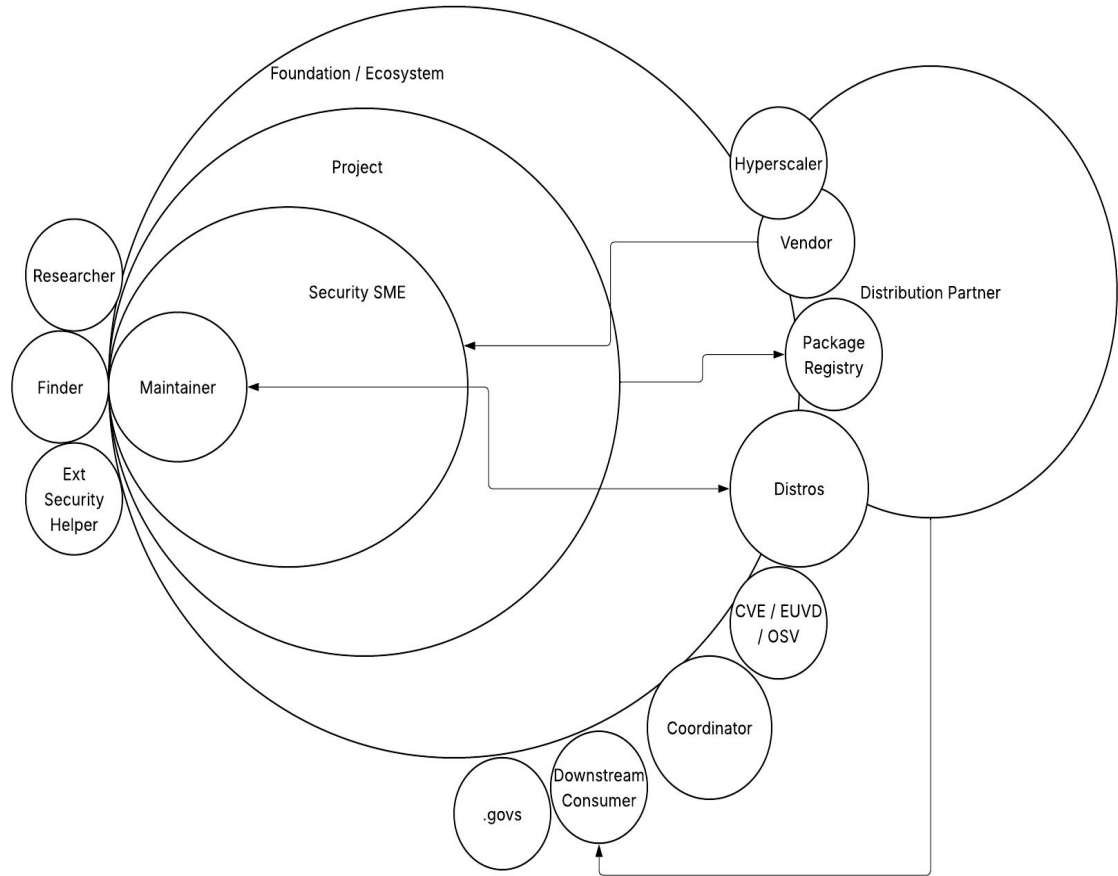
OSS CVD involves numerous unique stakeholders who must be accounted for when revamping security processes.

Intersecting Circles of Trust

These overlapping groups each play a critical role in finding, fixing, and disclosing vulnerabilities.

Diverse Coordination Roles

Different stakeholders maintain distinct relationships with the project and have varying roles to play within coordination.



Principles that shape the Akrites

Confidentiality is the first principle

An undisclosed vulnerability in a widely deployed package is, in effect, a weapon. The model is built first to prevent leaks.

Least privilege across the program

Access follows need-to-know, not membership tier. No single party sees the full set of packages critical infrastructure depends on.

Technical contribution is the price of admission

Participants build and ship fixes, or fund the work that does. This is not a pay-to-read service.

One maintainer-facing front door

Fixes are published into the package's original namespace wherever possible, coordinated by the SIRT.

Synchronized disclosure

Upstream maintainers enter the same CVD window at the same moment. No participant gets a head start.

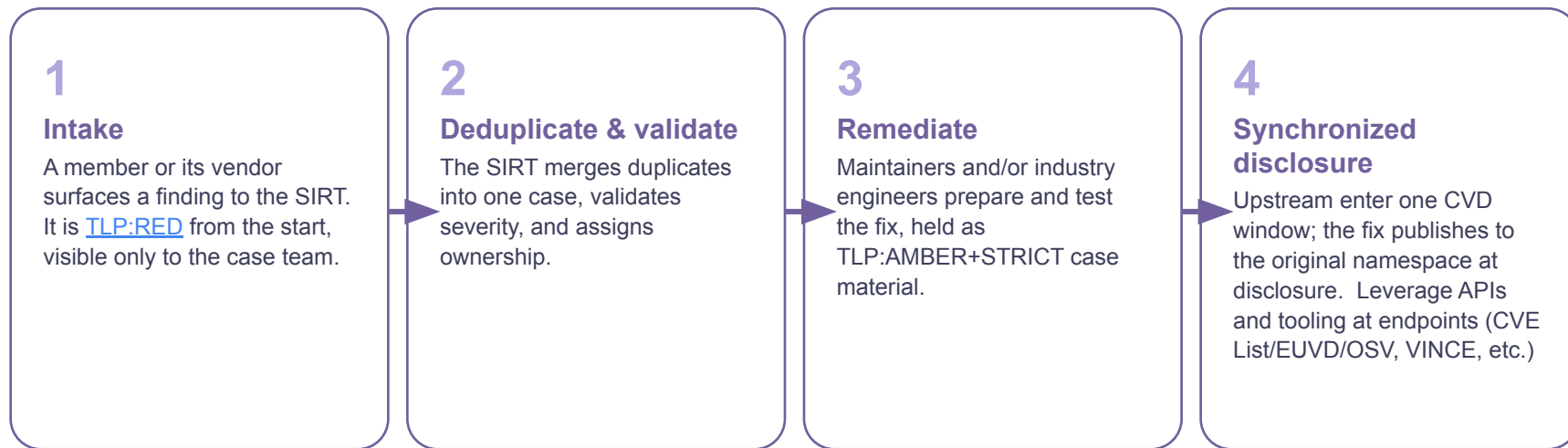
Meet maintainers where they are

Akrites contributes fixes; it does not impose process or tooling. Maintainers keep final authority over their releases.

How the SIRT will function

How a vulnerability flows through the program

Every finding follows the same path so upstream maintainers face one predictable partner and members get consistent embargo handling.



Where no maintainer is responsive, the SIRT may, with TOC approval, publish a time-bounded hardened fork under a reserved namespace. Advisories and CVEs issue through the Linux Foundation's CNA authority.

Confidentiality Framework

End-to-end protection for critical vulnerability data across infrastructure, operations, and external coordination.

● ● ● TLP 2.0 Governed



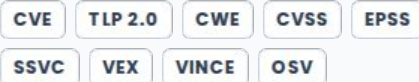
Confidential Hardened Cloud Infrastructure

- **Isolated Enclaves:** Dedicated environments for vulnerability analysis, POC/POV verification, & patch creation.
- **Analyst Workbench:** Provided via secure, monitored virtual machines.
- **Strict Governance:** Strong access controls, MFA, and continuous monitoring.
- **Role-Based Access:** Vulnerability reports restricted to Finders during triage.
- **Patch Bundles:** Limited to Finders & SIRT during Coordination & Disclosure.
- **TLP Gatekeeping:** Restricts access across all phases of engagement.



A Shared, Dedicated SIRT

- **Centralized Team:** Security Incident Response Team validates & deduplicates all findings.
- **Resolution Management:** Coordinates end-to-end fix validation & upstream patching.
- **Industry Standards Integration:** Built around trusted frameworks and taxonomy tools.



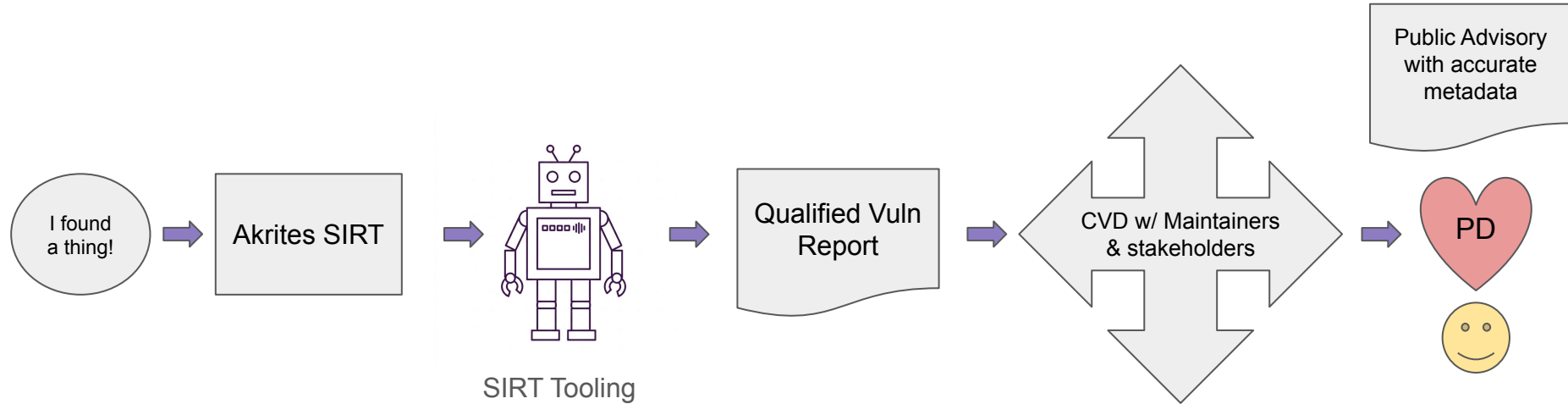
Confidential Coordination

- **CVD Tooling:** Platforms like VINCE assist in case management and multi-party coordination.
- **TLP Protocol Coverage:** Protects all involved parties and artifacts until Public Disclosure (PD).
- **Secure Upstream Tools:** Confidential reporting tools utilized for safe reporting (e.g., GitHub Private Vulnerability Reporting).

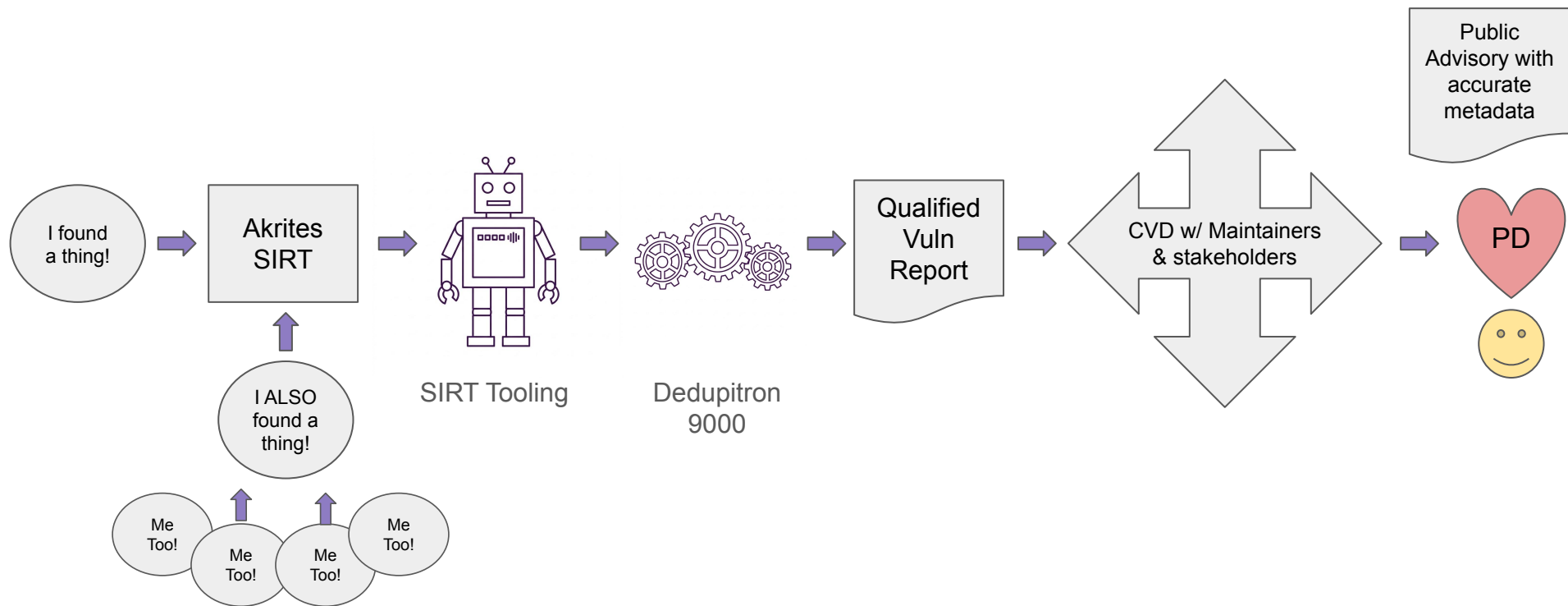
TLP 2.0 Information Sharing Standard

TLP Designation	Sharing Boundary	Application in Vulnerability Handling
TL TLP:RED	Individual Recipients Only	Initial unverified vulnerability report, 0-day disclosures, and high-risk exploit POCs.
TL TLP:AMBER+STRICT	Recipient Organization Only	Internal patch engineering and verification within the vendor organization.
TL TLP:AMBER	Organization & Clients / Partners	Pre-disclosure advisories shared with trusted coordinators (e.g. VINCE) and impacted partners.
TL TLP:GREEN	Community / Industry Sector	Broad threat intelligence sharing with ISACs and partner security teams.
TL TLP:CLEAR	Public Release	Final CVE advisory, published patch release notes, and public vulnerability write-up.

OSS-SIRT Process (simple)



OSS-SIRT Process (Multiple Finders)



What's Next?

A journey of a thousand miles begins with a single step

- SIRT tooling will be online and ingesting member reports Q32026
- SIRT accepting broader Clearinghouse reports Q32026
- LLM-assistance security research best practices co-published with the OpenSSF Q42026
- OpenSSF's [OSS-CRS](#) (Cyber Reasoning System) available for broader use Q42026
- Akrites begins accepting unsolicited reports EoY2026



Which path do you want to follow?



Patch the commons, together.

Join critical infrastructure operators and their vendors in building a confidential, coordinated defense for the open source software we all rely on.

www.akrtites.org

[Inquire About Membership](#)

Thank you!



CRob_at_Akrites_dot_org



@SecurityCRob



@SecurityCRob@infosec.exchange



<https://github.com/SecurityCRob>



[The Security Unhappy Hour,](#)
[Chips & Salsa](#)
[What's in the SOSS?](#)



<https://www.linkedin.com/in/darthcrob/>

Appendix



What is a SIRT?

What is a SIRT?

In a traditional enterprise there are a few teams that “do security”:

CSIRT - Corporate/Computer Incident Response Team - an internal security team focused on users, corporate data, and company infrastructure

PSIRT - Product Security Incident Response Team - a team focused on a company’s product portfolio, helping ensure security practices are followed and vulnerabilities are remediated

CERT or National CSIRT - Computer Emergency Response Team - a coordinator, typically a government-backed entity helping protect a specific sector or national constituency

SIRT - Security Incident Response Team - The SIRT is a team dedicated to helping find, document, disclose, coordinate, and fix security vulnerabilities in open source software; it is neither an internal corporate function nor a product-focused group

Terms

Glossary of Terms

CVD - Coordinated Vulnerability Disclosure - <https://www.first.org/global/sigs/vulnerability-coordination/multiparty/guidelines-v1.1>

CVE - Common Vulnerabilities & Exposures - <https://www.cve.org/About/Overview>

CVSS - Common Vulnerability Scoring System - <https://www.first.org/cvss/>

CWE - Common Weakness Enumeration - <https://cwe.mitre.org/>

EPSS - Exploit Prediction Scoring System - <https://www.first.org/epss/>

EUVD - European Vulnerability Database - <https://euvd.enisa.europa.eu/>

FIRST - Forum of Incident Response and Security Teams - www.first.org

IR - Incident Response

NVD - National Vulnerability Database - <https://nvd.nist.gov/>

OSS - Open Source Software

OSV - Open Source Vulnerability (database) - <https://osv.dev/>

PD - Public Disclosure

POC - Proof of Concept

POV - Proof of Vulnerability

SME - Subject Matter Expert

SIRT - Security Incident Response Team - [FIRST Security Team Definitions](#)

SSVC - Stakeholder Specific Vulnerability Categorization - <https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc>

TLP - Traffic Light Protocol - <https://www.first.org/tlp/>

VDP - Vulnerability Disclosure Program

VDR - Vulnerability Disclosure Report

VM - Vulnerability Management

Legal Notice

Copyright © Akrites®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners. Per the Akrites Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share: copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt: remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution: You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions: You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.